GUIA GENERAL · para todo el equipo

PAI-3 VULNAWEB — Guia general

Que es el trabajo, que hay que entregar y quien hace que. Leela entera antes de empezar.

1. De que va

Hacemos de **auditores de seguridad** para una universidad ficticia (U-Secure). Hay que revisar lo segura que esta su infraestructura y entregar un informe con las pruebas. Se divide en **cuatro auditorias independientes**, cada una con su herramienta.

La infraestructura son dos bloques: los **endpoints** (ordenadores Linux del personal, sus navegadores y los moviles personales que usan para la universidad) y las **aplicaciones web** de la universidad (que se prueban desde fuera, como un atacante).

2. Las cuatro tareas

#	Tarea	Herramienta	Objetivo concreto
1	Sistemas informaticos	Lynis	2-3 equipos Linux con **hardening index ≥ 70**, cada medida justificada
2	Navegador web	Politicas (Firefox)	Directivas de bastionado aplicadas y verificadas en `about:policies`
3	Sistema movil	Malwarebytes/Koodous + ADB	**≥ 2 moviles** auditados y bastionados segun la checklist
4	Sistema web	OWASP ZAP	Trazabilidad HTTP/HTTPS + **≥ 3 vulnerabilidades** OWASP Top 10 + mitigacion

Estandares que citar en el informe: OWASP Top 10, CIS Benchmarks, NIST SP 800-115 y ENS (categoria Alta).

3. Reparto (somos 3)

Persona	Partes	Necesita
Persona 1	1. Sistemas + 2. Navegador	2-3 VM Linux; las dos partes van en la misma maquina
Persona 2	3. Movil + juntar el PDF final	2 moviles Android y un PC con `adb`
Persona 3	4. Web (ZAP)	Docker con DVWA y ZAP

Cada uno tiene su guia detallada en un PDF aparte. Cada persona escribe su seccion del informe; la Persona 2 lo junta y exporta el PDF.

4. Calendario (quedan ~9 dias)

1. **1-2 nov:** cada uno instala sus herramientas y saca el primer escaneo "antes". Guardar logs desde el principio.
2. **3-4 nov (seguimiento):** llegar con el escaneo inicial y la lista de medidas a aplicar.
3. **4-6 nov:** aplicar medidas, repetir escaneos, capturas. Web: las 3 vulnerabilidades explotadas.
4. **7-8 nov:** cada uno escribe su parte (~3 paginas).
5. **9 nov:** juntar informe, resumen ejecutivo, comprobar ≤ 15 paginas, montar el zip.
6. **10 nov (manana):** subir `PAI3-ST5.zip` a la Ensenanza Virtual. No apurar a las 23:59.

5. Que se entrega

Un zip `PAI3-ST5.zip` (este repositorio comprimido + el PDF del informe) subido **solo** a la actividad de la Ensenanza Virtual. Contiene:

- **Informe PDF, max. 15 paginas** (referencias y anexos no cuentan). Estructura obligatoria: portada e indice, resumen ejecutivo, y por cada auditoria: descripcion + plan de pruebas y resultados + conclusiones.
- **Evidencias tecnicas:** scripts, configuraciones y — obligatorio — los **logs** de todas las herramientas (Lynis, ZAP, movil). Sin log, la parte no esta demostrada.

> **Penalizaciones:** cada dia de retraso −10%; entregar por email o mensaje interno −10%. Hay seguimiento el 3-4 de noviembre.

6. Reglas del equipo

- **Solo entornos propios o de pruebas.** ZAP y los fuzzers nunca contra webs reales. Atacar sin autorizacion es delito.
- **Todo se documenta.** El informe exige justificar cada cambio (y por que se descarta otro).
- Cada log va a `evidencias/<parte>/` con fecha en el nombre.
- En VMs, **snapshot** antes de bastionar. Capturas de cada paso importante.
- Lo mas simple que cumpla el enunciado. Nada de anadir herramientas que no se piden.

7. Glosario rapido

Termino	Que es
Bastionado / hardening	Endurecer un sistema reduciendo su superficie de ataque.
Hardening index	Nota 0-100 que da Lynis. La politica exige ≥ 70.
Endpoint	Equipo final de un usuario (PC, portatil, movil).
BYOD	Dispositivo personal usado para trabajo/estudio.
DAST / SAST	Probar la web desde fuera (caja negra) / leyendo el codigo (caja blanca).

Proxy interceptor / MitM	Intermediario que ve y puede editar el trafico navegador-servidor.
Fuzzing	Repetir una peticion con muchas cadenas de ataque de un diccionario.
OWASP Top 10	Lista de los 10 riesgos web mas importantes.

8. Mapa de codigo → tarea

Qué fichero del repo usa cada parte (todo cuelga de la raíz `PAI3-lab/`):

Tarea	Ficheros a usar	Para que
1. Sistemas (Lynis)	`sistemas/run_lynis.sh`, `sistemas/hardening.sh`, `sistemas/sysctl-hardening.conf`, `sistemas/custom.prf`	Escanear, bastionar y re-escanear
2. Navegador	`navegador/firefox/policies.json`, `navegador/desplegar.sh`, `navegador/directivas.md`	Desplegar y justificar las directivas
3. Movil	`movil/auditar_android.sh`, `movil/checklist.md`	Volcar estado por ADB y rellenar la checklist
4. Web (ZAP)	`web/payloads/sqli.txt`, `web/payloads/xss.txt` (+ DVWA por Docker y ZAP, externos)	Fuzzing de las vulnerabilidades
Comun	`check.sh`	Comprobar que los JSON y los scripts estan bien